

第4章作业

题目

1.什么是数据库的安全性?

答：数据库的安全性是指保护数据库以防止不合法的使用所造成的数据泄露、更改或破坏。

2.举例说明对数据库安全性产生威胁的因素。

答：

1. 非授权用户对数据库的恶意存取和破坏。
2. 数据库中敏感或者重要的数据泄露。
3. 安全环境的脆弱性。

3.试述实现数据库安全性控制的常用方法和技术。

答：

- (1) **用户身份鉴别**：系统提供一定的方式让用户标识自己的名字或身份。每次用户要求进入系统时，由系统进行核对，通过鉴定后才提供系统的使用权。
- (2) **存取控制**：通过用户权限定义和合法权检查确保只有合法权限的用户访问数据库，所有未被授权的人员无法存取数据。
- (3) **视图机制**：为不同的用户定义视图，通过视图机制把要保密的数据对无权存取的用户隐藏起来，从而自动地对数据提供一定程度的安全保护。
- (4) **审计**：建立审计日志，把用户对数据库的所有操作自动记录下来放入审计日志中，DBA 可以利用审计跟踪的信息，重现导致数据库现有状况的一系列事件，找出非法存取数据的人、时间和内容等。
- (5) **数据加密**：对存储和传输的数据进行加密处理，从而使得不知道解密算法的人无法获知数据的内容。

4.什么是数据库中的自主存取控制方法和强制存取控制方法?

答:

自主存取控制方法: 定义各个用户对不同数据对象的存取权限。当用户对数据库访问时首先检查用户的存取权限。防止不合法用户对数据库的存取。

强制存取控制方法: 每一个数据对象被(强制地)标以一定的密级, 每一个用户也被(强制地)授予某一个级别的许可证。系统规定只有具有某一许可证级别的用户才能存取某一个密级的数据对象。

5.对下列两个关系模式: 学生(学号,姓名,年龄,性别,家庭住址,班级号) 班级(班级号,班级名,班主任,班长)。请用SQL的GRANT语句完成下列授权功能。

- ① 授予用户 U1 对两个表的所有权限, 并可给其他用户授权。
- ② 授予用户 U2 对“学生”表具有查看权限, 对“家庭住址”具有更新权限。
- ③ 将对“班级”表查看权限授予所有用户。
- ④ 将对“学生”表的查询、更新权限授予角色 R1。
- ⑤ 将角色 R1 授予用户 U1, 并且 U1 可继续授权给其他角色。

答:

```
1. GRANT ALL PRIVILEGES ON TABLE Student, Class TO U1 WITH GRANT OPTION;  
2. GRANT SELECT, UPDATE('家庭住址') ON TABLE Student TO U2;  
3. GRANT SELECT ON TABLE Class TO PUBLIC;  
4. GRANT SELECT, UPDATE ON TABLE Student TO R1;  
5. GRANT R1 TO U1 WITH ADMIN OPTION; -- 注: 角色授权传递通常用 WITH ADMIN OPTION
```

6.今有两个关系模式: 职工(职工号,姓名,年龄,职务,工资,部门号) 部门(部门号,名称,经理名,地址,电话号)。请用 SQL 的 GRANT 和 REVOKE 语句(加上视图机制)完成以下授权定义或存取控制功能。

- ① 用户王明对两个表有 SELECT 权限。
- ② 用户李勇对两个表有 INSERT 和 DELETE 权限。
- ③ 每个职工只对自己的记录有 SELECT 权限。
- ④ 用户刘星对职工表有 SELECT 权限, 对“工资”字段具有更新权限。
- ⑤ 用户张新具有修改这两个表的结构权限。

⑥ 用户周平具有对两个表所有权限(读,插,改,删数据), 并具有给其他用户授权的权限。

⑦ 用户杨兰具有从每个部门职工中 SELECT 最高工资、最低工资、平均工资的权限, 但不能查看每个人的工资。

答:

```
/* 职工: EMP    部门: DEPT */
1. GRANT SELECT ON TABLE EMP, DEPT TO '王明';
2. GRANT INSERT, DELETE ON TABLE EMP, DEPT TO '李勇';
3. GRANT SELECT ON TABLE EMP WHEN USER() = NAME TO ALL;
4. GRANT SELECT, UPDATE('工资') ON TABLE EMP TO '刘星';
5. GRANT ALTER TABLE ON TABLE EMP, DEPT TO '张新';
6. GRANT ALL PRIVILEGES ON TABLE EMP, DEPT TO '周平' WITH GRANT OPTION;
7. /* 首先建立一个视图。然后对这个视图定义杨兰的存取权限。*/
   CREATE VIEW 部门工资 AS
   SELECT DEPT.名称, MAX(工资), MIN(工资), AVG(工资)
   FROM EMP, DEPT
   WHERE EMP.部门号 = DEPT.部门号
   GROUP BY EMP.部门号;

   GRANT SELECT ON TABLE 部门工资 TO '杨兰';
```

7.针对第6题中①~⑦的每一种情况, 撤销各用户所授予的权限。

答:

```
1. REVOKE SELECT ON TABLE EMP, DEPT FROM '王明';
2. REVOKE INSERT, DELETE ON TABLE EMP, DEPT FROM '李勇';
3. REVOKE SELECT ON TABLE EMP WHEN USER() = NAME FROM ALL;
4. REVOKE SELECT, UPDATE ON TABLE EMP FROM '刘星';
5. REVOKE ALTER TABLE ON TABLE EMP, DEPT FROM '张新';
6. REVOKE ALL PRIVILEGES ON TABLE EMP, DEPT FROM '周平';
7. REVOKE SELECT ON TABLE 部门工资 FROM '杨兰';
   DROP VIEW 部门工资;
```

8.理解并解释强制存取控制机制中主体、客体、敏感度标记的含义。

答:

主体: 系统中的活动实体, 既包括 DBMS 所管理的实际用户, 也包括代表用户的各进程。

客体：是系统中的被动实体，是受主体操纵的，包括文件、基表、索引、视图等。

敏感度标记：对于主体和客体，DBMS 为它们每个实例（值）指派一个敏感度标记（Label）。敏感度标记被分成若干级别，例如绝密（Top Secret）、机密（Secret）、可信（Confidential）、公开（Public）等。主体的敏感度标记称为**许可证级别**，客体的敏感度标记称为**密级**。

9.举例说明强制存取控制机制是如何确定主体能否存取客体的。

答：

当某一用户以某一敏感度标记注册入系统时，系统要求他对任何客体的存取必须遵循如下规则：

1. 仅当主体的许可证级别**大于或等于**客体的密级时，才能**读取**相应的客体。
2. 仅当主体的许可证级别**小于或等于**客体的密级时，才能**写**相应的客体。

10.什么是数据库的审计功能，为什么要提供审计功能？

答：

审计功能是指 DBMS 的审计模块在用户对数据库执行操作的同时，把所有操作自动记录到系统的审计日志中。

原因：因为任何系统的安全保护措施都不是完美无缺的，蓄意盗窃破坏数据的人总可能存在。利用数据库的审计功能，DBA 可以根据审计跟踪的信息，重现导致数据库现有状况的一系列事件，找出非法存取数据的人、时间和内容等。

思维导图

数据库安全性

安全标准与威胁

主要威胁：非授权存取、数据泄露、环境脆弱

安全标准：TCSEC/TDI标准、CC标准

存取控制技术 (DAC & MAC)

自主存取控制 DAC `GRANT SELECT ON Student TO U1`

强制存取控制 MAC 主体许可证 $\geq$ 客体密级才可读

角色与视图机制

角色 (CREATE ROLE, 打包权限简化管理)

视图 (为不同用户定义视图隐藏敏感数据)

审计与加密

安全审计 (AUDIT记录操作日志)

数据加密 (存储加密、SSL传输加密)

其他保护技术

推理控制、隐蔽信道

数据隐私 (k-匿名标准)